

Transport Layer Security Overview

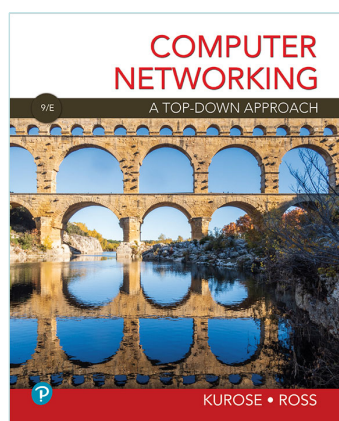


© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

1

Reference book



Chapter 8 Security in Computer Networks

© M. C. Calzarossa 2026

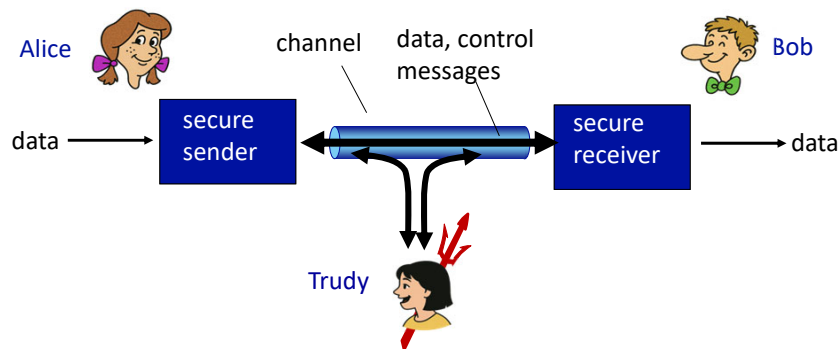
Enterprise Digital Infrastructure

2

Scenario

Bob and Alice want to communicate “securely”

Trudy is the bad guy who may intercept, delete and add messages (e.g., sniffing, tampering, impersonation, hijacking)



3

Transport Layer Security

The Transport Layer Security (TLS) is a standard application layer protocol whose primary goal is to provide a secure conversation over an insecure channel between two communicating parties (even if they do not know each other)

In 1994 Netscape proposed the Secure Socket Layer (SSL) protocol to protect emerging services (e.g., e-commerce) deployed on the web (**http+ssl=https**)

The idea was standardized by IETF as TLS five years later [RFC 2246 “The TLS Protocol Version 1.0” published in 1999]

New versions, i.e., TLS 1.1 and TLS 1.2, were released in 2006 and 2008

The current version TLS 1.3 is a *major redesign* of TLS 1.2 to improve performance and robustness [RFC 8446 “The Transport Layer Security (TLS) Protocol Version 1.3” published in 2018]

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

4

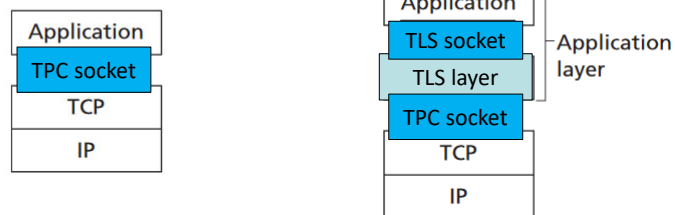
TLS characteristics

TLS is the most prominent and the *de facto* secure protocol of choice

It provides end-to-end security without the need of any intermediary

It is used to protect billions of Internet connections every day (e.g., web, ssh, DNS)

TLS resides at the application layer and requires reliability and in-order data streams from transport protocols



OpenSSL is an open source robust, commercial-grade and full-featured toolkit for the SSL/TLS protocols

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

5

Secure conversation requirements

1. Confidentiality: only sender and intended receiver understand message content
 - This prevents eavesdropping attacks
2. Integrity: sender and receiver want to ensure messages are not altered (in transit or afterwards) without detection
 - This prevents Man-In-The-Middle attacks
3. Authentication: sender and receiver want to confirm the identity of each other
 - This prevents impersonation attacks

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

6

Secure conversation implementation

1. Confidentiality
 - Symmetric key encryption for application data
 - Usually Advanced Encryption Standard (AES)
2. Integrity
 - Cryptographic hashing based on Authenticated Encryption with Additional Data (AEAD)
 - Usually AES-GCM (Galois/Counter Mode)
3. Authentication
 - Public key cryptography and nonce based on X.509 certificates signed by a mutually trusted third party
 - Usually server authenticated only

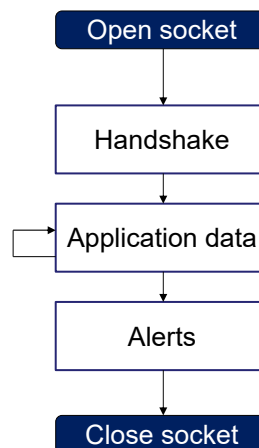
© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

7

Main phases of a secure conversation

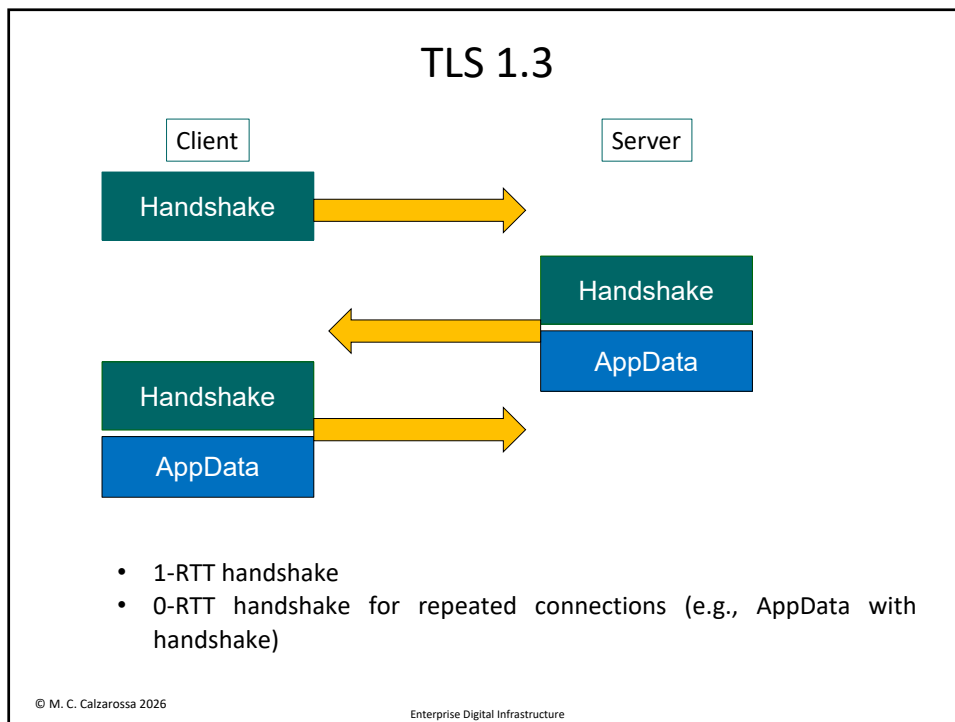
1. Handshake
 - Agree a cipher suite
 - Agree a master secret key
 - Authentication using certificate(s)
2. Application Data
 - Symmetric key encryption
 - AEAD cipher modes
3. Alerts
 - Graceful closure
 - Problems detected



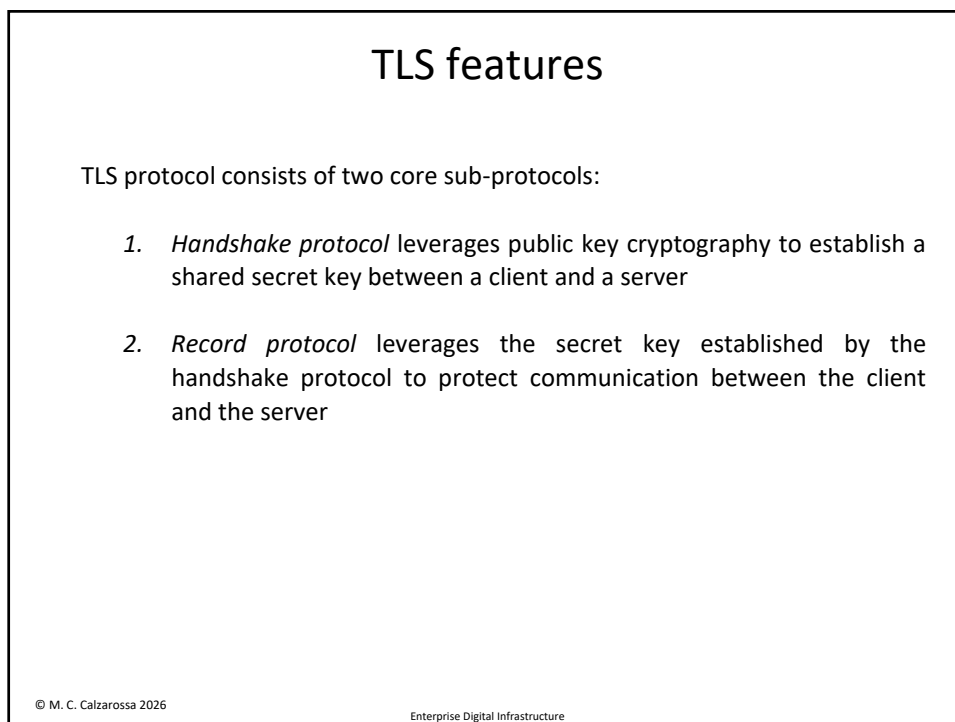
© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

8



9



10

Handshake protocol

The interactions between client and server start with an *handshaking phase*:

- Preliminary standard TCP three-way handshaking
- *Specific* handshake to establish the *cryptographic parameters* for their subsequent interactions:
 1. Negotiate the version of the protocol and the set of cryptographic algorithms (e.g., algorithms for key generation, encryption, Message Authentication Code, digital signature) to be used
 2. Duffie-Hellman key agreement (i.e., public-private key pair)
 3. Additional parameters

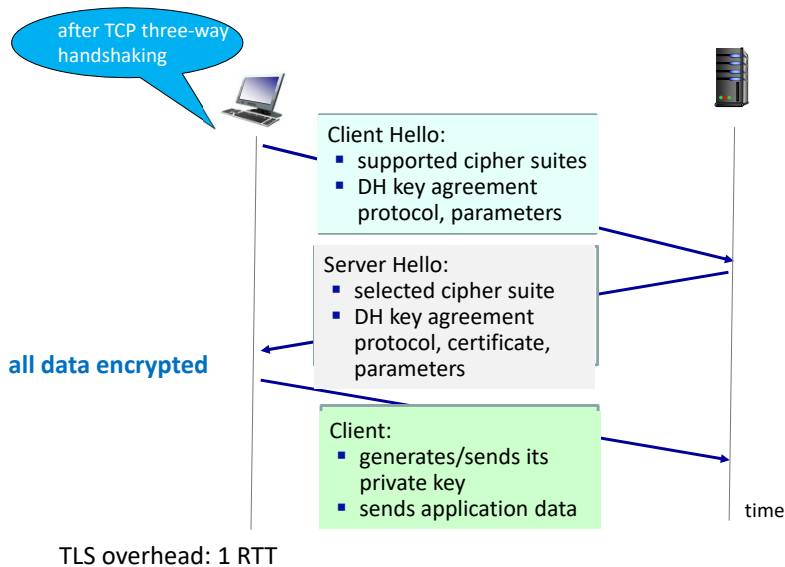
Once the secure connection is established, the secret key is used by the record protocol to protect (i.e., encrypt/decrypt) the application layer traffic

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

11

Client/server interactions under TLS 1.3



© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

12

TLS 1.3 with 0-RTT

The client “resumes” an earlier connection with a server

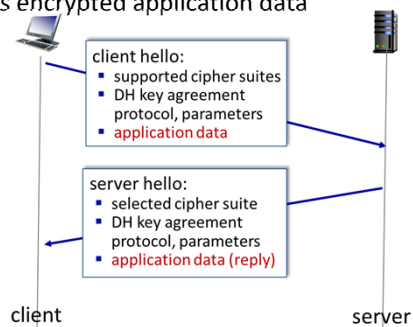
This is accomplished by storing secret information (e.g., session ticket) of a previous session for possible future usage

Application data are encrypted using the key from the earlier connection

Initial Hello message of the client contains encrypted application data

+ No overhead

- Vulnerable to replay attacks



© M. C. Calzarossa 2026

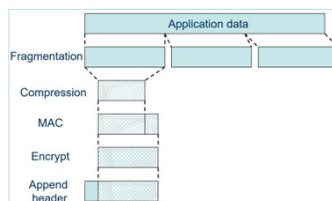
Enterprise Digital Infrastructure

13

Record protocol

On the sender side, the record protocol

- Reads the messages to transfer
- Fragments messages into manageable chunks of data (optionally compresses the data)
- Calculates a Message Authentication Checksum
- Encrypts the data
- Adds a header
- Sends encrypted data to transport layer



On the recipient side, the operations are performed in the reverse order

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

14

Alert protocol

Alert protocol is used to send signals between clients and servers (e.g., causes of protocol failures)

The alert messages are protected by the record protocol

To avoid truncation attacks, an alert is used to notify the start of a TCP connection closing

A standard **TCP FIN** will follow

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

15

Datagram Transport Layer Security

Applications (e.g., media streaming, Internet telephony, online gaming) use UDP transport protocol because of the delay-sensitive nature of transported data

Datagram Transport Layer Security (DTLS) protocol offers communication security *protection* for applications using UDP transport protocol [RFC 9147 “The Datagram Transport Layer Security (DTLS) Protocol Version 1.3” published in April 2022]

It is based on TLS and provides the same security level

DTLS has the benefits of datagram protocols: lower overhead and reduced latency

DTLS does not guarantee the order of message delivery, or even that messages will be delivered at all

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

16